metricstream

AI-Driven Continuous Control Monitoring

The New Playbook for Proving Cyber Resilience



Table of Contents

Introduction 3

Chapter 1: What "Control Health" Actually Means 5

Chapter 2: Why Continuous Control Monitoring is a strategic investment? 7

Chapter 3: From Theory to Practice: Getting Started 9

How MetricStream Can Help 12

Introduction

THE CISO SURVIVAL PROBLEM: YOU'RE COMPLIANT. BUT ARE YOU RESILIENT?

Corporate investment in compliance is increasing, with organizations leveraging technology to manage and improve processes. For example, the banking sector alone spent USD 200 million annually on compliance in 2025. Organizations are actively implementing frameworks and controls and conducting audits. Yet, breaches continue to rise. The Identity Theft Resource Center's (ITRC) H1 2025 report shows an 11 percent increase in data compromises in the first half of 2025 compared to the same period in 2024. The unfortunate truth is that passing audits, and having compliance frameworks does not automatically ensure resilience.

Modern enterprises now operate in an environment marked by rapidly escalating, rapidly evolving risks driven by AI. Threat actors exploit misconfigurations, privilege gaps, and control failures in near real time, while organizations continue to validate controls with periodic audits. This creates a significant mismatch between the speed at which threats move and the pace at which assurance is established.

Understandably, regulators are now demanding "always on" compliance and control processes with a strong focus on resilience and accountability. Recent regulations have emphasized resilience and demonstrable, continuous control effectiveness:

- The NIST CSF 2.0 now includes a new Govern function to embed cybersecurity into enterprise risk management and not just IT operations. It requires organizations to establish and continuously monitor their cybersecurity risk strategy, policies and expectations. The Govern function is expected to build resilience and improve risk tolerance, accountability, policy setting, and continuous oversight across other functions like Identify, Protect, Detect, Respond, and Recover.
- The NIS2 makes cybersecurity a leadership responsibility by requiring senior management to approve and oversee cybersecurity measures. They are also expected to undergo cybersecurity training so they understand the risks and obligations tied to compliance. Failure to comply can lead to personal consequences by way of temporary suspension from management roles.
- DORA mandates comprehensive ICT risk management frameworks for financial entities. The framework must be built to identify, assess, mitigate, monitor, and report ICT-related risk across the business. It also requires clear governance, defined reporting lines, risk tolerance thresholds, incident classification, and continuous monitoring of infrastructure, human, and third-party risks.

Traditional GRC approaches that were built for a bygone era cannot deliver on the regulatory demand for continuous monitoring, real-time visibility into controls, or accountability and ownership. They still rely on periodic control testing that can't catch lapses in real time, and the main focus is on audit preparation and documentation rather than real-time responsiveness. Closing this gap between regulatory demands and GRC functions calls for a shift from mere compliance-focused processes to continuous, intelligence-led control assurance for enterprise resilience.

The challenge is no longer just passing audits. The challenge is proving cyber resilience continuously — with real-time visibility into control health, risk exposure, evidence, ownership, remediation, and business impact. To prove cyber resilience, organizations need an AI-first connected IT & Cyber GRC program that brings together risk, compliance, policies, vendors, evidence, vulnerabilities, controls, issues, and remediation.

32% of global organizations were fined by regulators for data-breach-related infractions.

An aggregate total of EUR1.2 billion in fines was issued across Europe in 2024.

Organizations detected compromises in a median of 10 days, but public disclosure lagged far longer, averaging 117 days.

Median disclosure delay was 73 days, and the gap increased from an average of 76 days in 2024 to 117 days in 2025, showing a growing audit and notification lag.



Chapter 1:
What "Control Health" Actually Means

Control health is inherently different from compliance status. A compliance status is a point-in-time check of controls on factors such as listing of a control on a policy, comprehensive testing, and sign-off in the annual review. Control health, on the other hand, refers to the continuous state of effectiveness of enterprise controls. A control may be well designed, documented, and audit-approved, but still suffer from occasional failures due to configuration drifts, system changes, integration gaps, or even human error.

In IT and cyber risk management, control health must be further understood in context. A control protecting a low-risk internal system does not carry the same business importance as a control protecting a Crown Jewel asset. Cyber resilience improves only when control health is measured not just broadly but based on business criticality.

To ensure resilience beyond mere compliance, control health assessment must be continuous so that any lapses can be identified and corrected in real time.

The control health should tell you whether that control is effective, operating as expected, supported by current evidence, linked to the right risks, and protecting the assets that matter most.

The difference lies in the shift from asking "are we compliant?" to "are our controls working right now?"

Control health is the real-time measure of whether a control is designed correctly, operating effectively, supported by current evidence, and reducing the intended risk.

Compliance Mindset	Control Health Mindset
Periodic Validation – Did we pass the audit?	Continuous Monitoring – Are the controls working right now?
Audit-focused – Collect evidence for the auditor	Risk driven – does it address the intended risk?
Static documentation – Have we ticked off all the requirements for the audit?	Dynamic Assurance – Evidence of real time control performance
Retrospective – Did we pass the audit last quarter?	Real Time and Continuous – Are we resilient right now?

Three key factors jointly contribute to control health:

Design Effectiveness
Assessing if the control effectively addresses the intended risk

Operating Effectiveness
Evaluating if the control functions consistently operate in real-world conditions

Evidence Continuity
Proof that the control is continuously working

Traditional periodic audit cycles pose a serious risk to enterprises in this era of AI-powered attacks. Threat actors are increasingly leveraging AI to launch sophisticated attacks between audit cycles when visibility is low. A temporary misconfiguration may leave a system unintentionally exposed, a critical patch may be delayed due to operational constraints, or access privileges may not be revoked in time. And threat actors may be ready and waiting to exploit these vulnerabilities, and may even go undetected till the next audit. The controls may be well designed, but without ongoing effectiveness assessments, the enterprise will remain at risk for breaches.



Chapter 2: Why Continuous Control Monitoring is a strategic investment?

More organizations are making the shift to continuous control monitoring (CCM), a technology-powered approach that continuously monitors and validates the effectiveness of enterprise controls. CCM leverages AI to predict and prevent control failures before they become actual breaches. This market is growing rapidly, and is forecast to reach USD 6.21 billion by 2033 from just USD 1.95 billion in 2024. But it is important for enterprises to understand that CCM does not represent just a security upgrade. Instead, it is a long-term strategic investment to ensure lower incident costs and penalties, quicker mitigation of risks, and ultimately, a crucial driver of stakeholder trust.

Audit Efficiency

Audits are time and labor-intensive. Teams spend weeks gathering retrospective evidence, validating control performance, and reconciling data across systems. This leaves room for errors and lapses. CCM transforms audit readiness by continuously collecting and validating control evidence and maintaining a centralized repository of control performance data. It also maps evidence to regulatory requirements. This helps reduce audit preparation time, and cut down manual effort. Most importantly, evidence is consistent, traceable, and always up to date.

Risk Reduction

In traditional environments, control risks go undetected between audit cycles, increasing the window of exposure. CCM can help detect control failures in real time and immediately flag issues like misconfigurations, failed alerts, or unauthorized access.

With integrations to security and enterprise tools, organizations can bring vulnerability and threat data into a governed GRC workflow — turning technical findings into prioritized issues, remediation actions, and executive-ready risk insights.

It can trigger automated alerts and remediation workflows. This allows organizations to act within minutes or hours, reducing the probability of breaches. CCM helps drive the shift from reactive incident response to proactive risk prevention.

Regulatory Confidence

CCM is a crucial asset for an organization amidst increasing regulator demand for governance, accountability and demonstrable operational resilience across sectors. Organizations can demonstrate real-time visibility into control health and provide on-demand, audit-ready compliance evidence.

A connected Cyber GRC platform helps teams monitor compliance status, open issues, control test results, evidence gaps, regulatory obligations, and remediation progress in real time.

This is particularly critical for frameworks like NIS2 Directive, Digital Operational Resilience Act (DORA), SOC 2, Health Insurance Portability and Accountability Act (HIPAA). For example, DORA mandates ICT governance, incident reporting, and third-party oversight within the financial sector. And within healthcare, HIPAA/HITRUST programs require control assurance to reduce the risk of exposure, downtime, or weak audit evidence. For organizations across both these highly regulated sectors, the cost of control failure is not limited to penalties; it also includes operational disruption, remediation costs, and significant damage to reputation and trust. With CCM in place, these enterprises can show clear accountability and ownership for controls across the enterprise and also respond quickly to regulatory queries with validated data.

Webinar Insight: Duplication makes continuous control monitoring harder. The same control often appears across NIST, DORA, GDPR, ISO 27001, SOC 2, and the EU AI Act under different names, forcing teams to map, test, and report it repeatedly. CCM works better when controls are harmonized once, reused across frameworks, and monitored continuously.

Watch the webinar recording

Read the Key Takeaways Blog

Based on MetricStream customer responses and the GRC Journey Business Value Calculator, organizations using MetricStream Cyber GRC have reported outcomes such as:

66%
reduction in the time taken to complete risk assessments.

37%
cost savings in risk assessments and associated processes

50%
time saved in tracking and linking policies to regulations

40%
reduction of evidence requests through de-duplication

Chapter 3:
From Theory to Practice: Getting Started

The transition to CCM requires a shift in how organizations prioritize, implement, and measure control effectiveness. Monitoring everything all at once is unlikely to yield the best results. Instead, organizations must start with a focused, risk-led strategy that delivers immediate value while building toward long-term maturity. There are 4 key factors to keep in mind when making this move:

1 Map Controls to Business Risk

Start by mapping controls directly to business risks instead of just focussing on framework compliance. Frameworks like the CIS Critical Security Controls and NIST Cybersecurity Framework provide a strong cybersecurity foundation, but their implementation must move beyond a tick in the box approach. For these to be fully effective, organizations must begin by identifying the controls that protect their most critical assets and processes, and prioritize continuous monitoring for them. This ensures alignment with not just regulatory requirements but also real-world risk scenarios.

2 Deploy AI Where It Matters Most

There is no doubt that AI is a powerful tool but it is important to deploy it strategically to reap the maximum benefit. Begin by automating important functions like evidence collection and anomaly detection that are both high-risk, low-visibility. Manual processes in these functions are error prone and failures are not likely to be identified quickly. AI can transform these processes by identifying controls drift, lapses, detecting unusual patterns, and flagging deviations in real time.



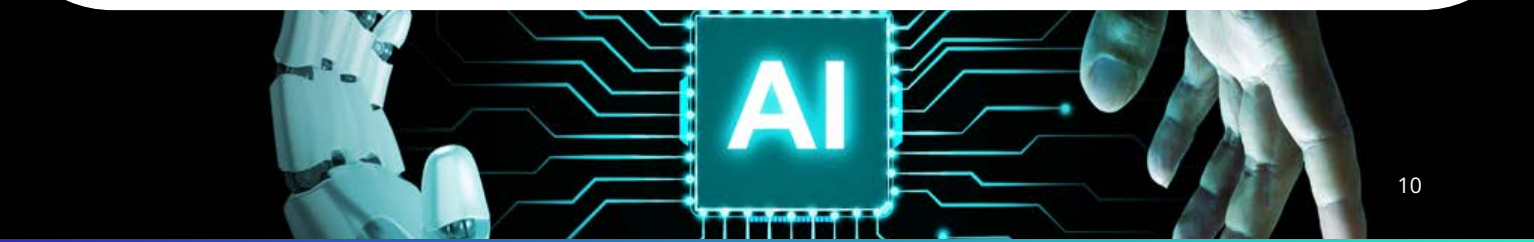
3 Track Control Health as a KPI

Traditionally, control health was assessed only during audits. But in a CCM model it must be tracked in real time, and must be treated as a measurable, visible performance indicator. Dashboards that provide near real time visibility into key indicators will help security and GRC teams to move from reactive issue remediation to proactively managing control performance. Over time, this will enable better forecasting of risk and more informed decision-making.

4 Close the Loop with the Board

Visibility alone is not sufficient, it is critical to translate control health data into business insights to close the gap between technical teams and the organization's leadership. When key stakeholders can understand how control failures can translate into losses or regulatory risks, they can take better, data powered decisions. This alignment is essential for embedding continuous control monitoring into the broader enterprise risk management strategy.

Security and GRC teams looking to make the shift to CCM must start small and scale up. Enterprise-wide implementation may be cost, time, and effort intensive. Instead, they must start by identifying high-risk, low-visibility controls, followed by automating evidence collection for a specific framework, such as SOC 2 CC6 controls. Early efforts should focus on establishing baseline metrics, such as the number of control failures detected, the time taken to remediate issues, and the completeness of evidence collection. These initial results provide tangible proof of value and help build momentum for broader adoption.



AI can accelerate every stage of implementation from identifying gaps in control coverage, automating the collection and validation of evidence, and generating insights that would be difficult to derive manually. Eventually, AI powered systems can help organizations move to predictive models where they can anticipate control failures before they occur and take quick preventive action.

Crawl

Start small with high-risk low visibility controls

Walk

Prioritize strategic AI deployment

Establish baseline metrics

Track KPIs

Translate CCM data into usable business insights

Run

Move to predictive models to anticipate control failures before they occur and take quick preventive action



How MetricStream Can Help

MetricStream's Cyber GRC solution leverages a comprehensive AI-driven approach to managing IT and cyber risk, helping organizations move from fragmented, periodic assessments to a proactive, always-on control environment. It enables them to identify, assess, and mitigate risks in real time while aligning with leading frameworks such as NIST, ISO 27001, and SOC 2.

At the core of the platform is its ability to continuously monitor control effectiveness and automate evidence collection, eliminating the manual overhead associated with traditional audits. This improves visibility into control performance and also ensures that organizations are always audit-ready, with traceable, up-to-date evidence available on demand.

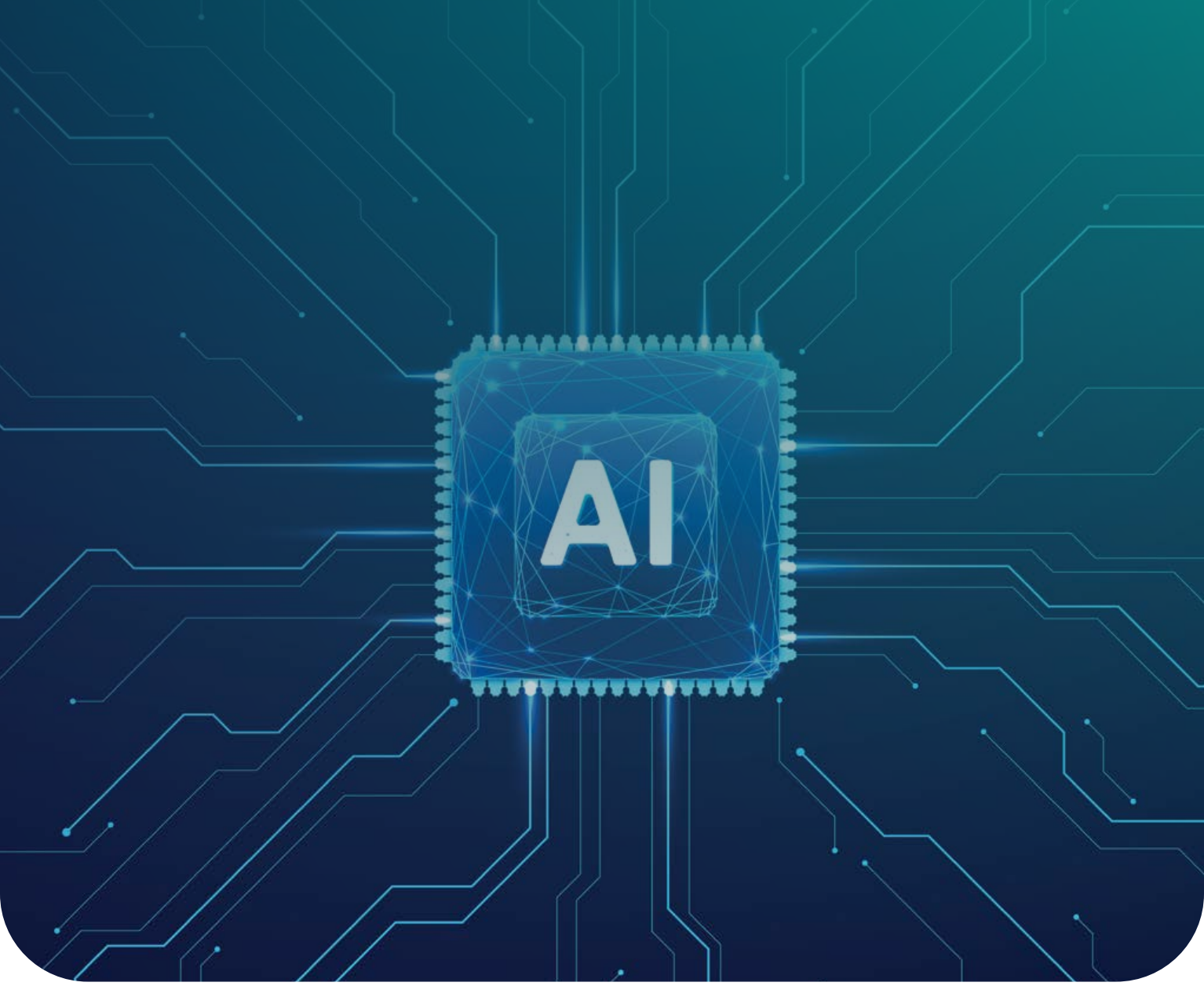
The platform also strengthens resilience by providing a unified view of threats, vulnerabilities, and third-party risks. By consolidating data from multiple sources and applying intelligent risk scoring, organizations can prioritize remediation efforts and respond faster to emerging risks. Automated workflows further streamline processes such as policy management, vendor risk assessments, and compliance tracking, ensuring consistency and accountability. It also helps organizations to quantify cyber risk in business terms, enabling security and GRC teams to communicate risk more effectively to executive stakeholders and prioritize investments based on potential business impact.

Cyber resilience requires more than passing audits. Organizations need continuous visibility into assets, risks, controls, vulnerabilities, vendors, evidence, and remediation. AI-first IT & Cyber GRC helps teams:

- Prioritize critical assets and Crown Jewel exposure
- Reduce repetitive assessment and evidence work
- Connect security tool data with GRC context
- Harmonize controls across frameworks
- Quantify cyber risk in business terms
- Govern issues and remediation to closure
- Report cyber resilience with confidence

See how MetricStream Cyber GRC works

Click Here



Contact Us | Request a Demo

© 2026 Copyright MetricStream. All Rights Reserved

metricstream